

Claude Fail-Case Analysis

Replication Package Document for
Beyond Labels: Evaluating LLMs on Vulnerable-Path Reconstruction

Aly Ahmad and Mahmoud Alfadel

This document accompanies the replication package for the paper above. It reports a case-level analysis of the 10 Claude Sonnet 4.5 fail cases in original Figure 4.

1 Which cases

Original Figure 4 is a single-run Claude Sonnet 4.5 NOR scatter over 105 CVEs. The 10 NOR = 0 cases points are the right-hand tail of the figure.

The 10 CVEs are CVE-2019-16056, CVE-2021-40323, CVE-2021-43837, CVE-2023-23930, CVE-2022-36081, CVE-2014-3498, CVE-2021-29433, CVE-2023-26051, CVE-2022-45064, and CVE-2021-41131.

2 Two dimensions

For every CVE we report both of the following.

Structural and contextual (descriptive). Path length, number of files, input tokens, and input lines, shown against the RQ₃ failure medians (path length 12, 2 files, 12,771 tokens, 852 lines). These summarize the typical low-performing RQ₃ case.

Qualitative reconstruction. A representative predicted path is compared with the retained reference paths and the CVE advisory and given one tag: T3 (CWE Misclassification), T1 (Endpoint Misidentification), or a reference-set gap (the prediction matches the advisory while the annotation encodes parallel flow).

3 Results

Five of the ten sit above the RQ₃ failure median for path length or number of files (CVE-2023-26051, CVE-2022-45064, CVE-2019-16056, CVE-2021-41131, CVE-2014-3498), and all five also exceed the input-size benchmarks. Two further cases have short, single-file paths but still exceed both input-size medians. Thus 7 of 10 exhibit relatively high path complexity, large input context, or both. Each of those cases still carries a reconstruction tag: structural complexity and a specific failure mode co-occur rather than substitute.

Across all 10, the tags are T3 for four (CVE-2014-3498, CVE-2022-45064, CVE-2023-26051, CVE-2019-16056); T1 for three (CVE-2022-36081, CVE-2021-29433, CVE-2021-41131); and a reference-set gap for three (CVE-2021-40323, CVE-2021-43837, CVE-2023-23930). The three reference-set gaps were excluded from the RQ₂ open-coding of model failure modes.

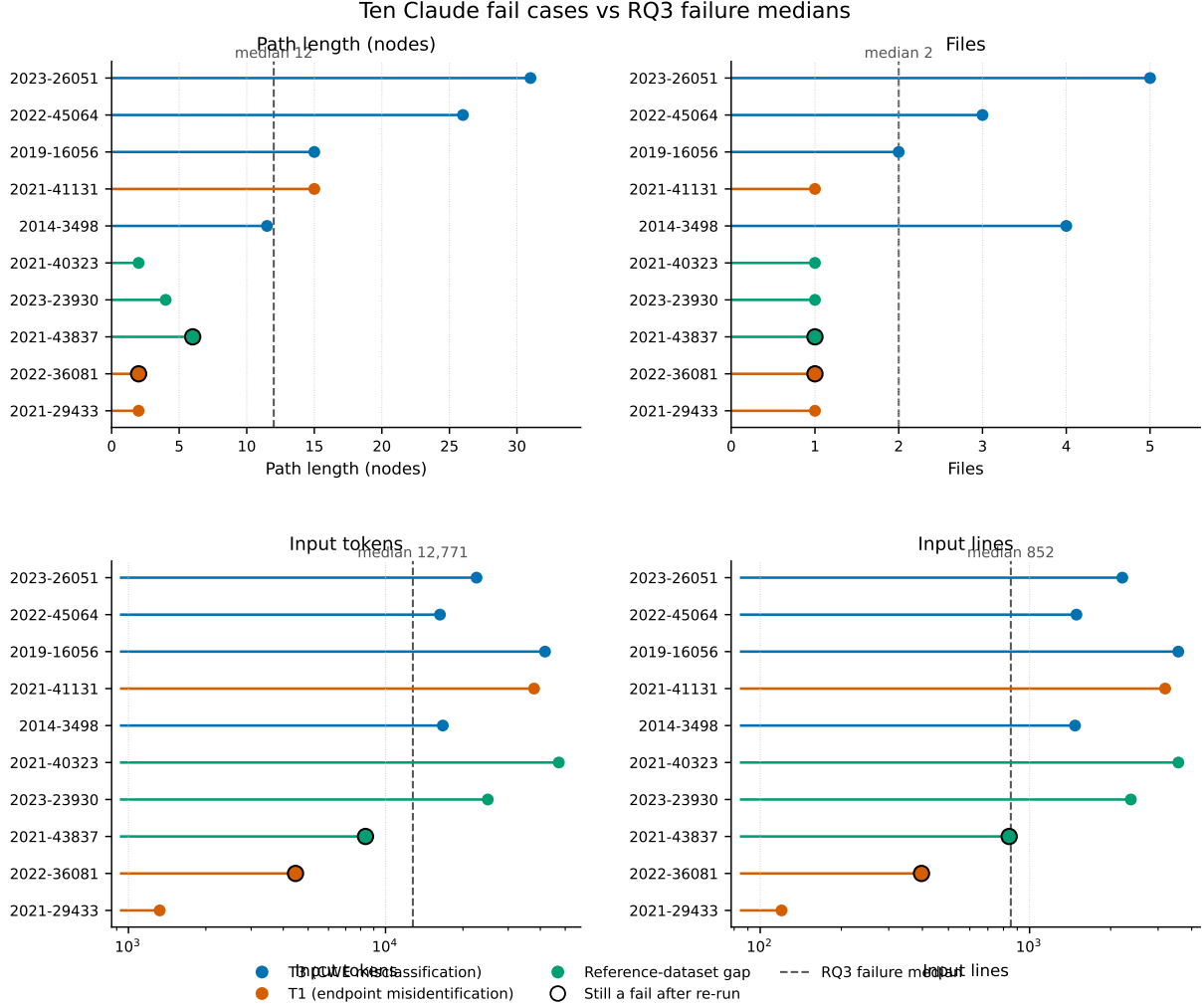


Figure 1: Path length, number of files, input tokens, and input lines for the 10 fail cases in Figure 4, relative to the RQ₃ failure medians (dashed lines). Color denotes the reconstruction tag (T3, T1, or reference-set gap). Tokens and lines are shown on a log axis.

T1, Endpoint Misidentification. CVE-2022-36081 is a CWE-22 path-traversal vulnerability involving the `/list/<folderpath>` endpoint, where the vulnerable flow can expose server file listings. The retained reference path follows `list.wiki` to `os.walk` and corresponds to this advisory-relevant endpoint. Claude instead reconstructs other flows in the same files related to page-name write/save operations and does not recover the advisory-relevant `/list` source-to-sink path.

T3, CWE Misclassification. CVE-2022-45064 is an include-based cross-site scripting vulnerability in Apache Sling. The retained reference path corresponds to this vulnerability. Claude instead reports path traversal, dispatcher SSRF, and filter-chain DoS candidates and does not identify the advisory-reported XSS flow.

Reference-set gap. CVE-2023-23930 concerns unsafe pickle-based serialization. Our retained path captures the same serialization flow, but the recorded sink is an exception-throwing line in

`serialize()` rather than the pickle operation itself. Claude identifies the pickle serialization of task input described by the advisory. Manual inspection indicates that the prediction represents a valid flow for the same CVE that is not captured by the retained reference path in our dataset, rather than a genuine reconstruction failure.